



Introductory Guidance to Cloud Controls Matrix (CCM)

About the CCM WG

The Cloud Control Matrix (CCM) Working Group (WG) comprises cloud industry professionals, such as cloud security professionals, auditors, operators and a great number of organizations, representing both providers and consumers of the cloud, as well as consulting/auditing firms.



The CCM v4.1 and its implementation guidelines stem from collective work built on group experience and feedback. As a result, it provides the community with one of its best vendor-neutral cloud security and privacy control frameworks.

Co-chairs supervise the WG activities. These individuals are highly experienced professionals representing three roles in the cloud industry: cloud service providers (CSPs), cloud service consumers (CSCs), and cloud auditors.

All contributions are personal and shall not constitute a commitment or opinion by the contributor or the contributor's organization.

© Copyright 2026 Cloud Security Alliance - All rights reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance "Cloud Controls Matrix (CCM) Version 4.1" at <http://www.cloudsecurityalliance.org> subject to the following: (a) the Cloud Controls Matrix v4.1 may be used solely for your personal, informational, non-commercial use; (b) the Cloud Controls Matrix v4.1 may not be modified or altered in any way; (c) the Cloud Controls Matrix v4.1 may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the Cloud Controls Matrix v4.1 as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance Cloud Controls Matrix Version 4.1. If you are interested in obtaining a license to this material for other usages not addressed in the copyright notice, please contact info@cloudsecurityalliance.org.

Acknowledgments

Author

Lefteris Skoutaris

Contributors

Jon-Michael Brook
Daniele Catteddu
Siddharth Nandakishoran
Michael Roza
Akash Verma

CSA Global Staff

Lefteris Skoutaris

Graphic Design

Stephen Lumpe

Table of Contents

About the CCM WG.....	2
Acknowledgments.....	3
Table of Contents.....	4
Executive Summary.....	6
1. Introduction.....	8
1.1 What is the Cloud Control Matrix.....	8
1.1.1 CCM Purpose and Scope.....	8
1.1.2 CCM Structure.....	9
1.1.3 CCM Domains Description.....	9
Audit and Assurance.....	9
Application and Interface Security.....	10
Business Continuity Management and Operational Resilience.....	10
Change Control and Configuration Management.....	11
Cryptography, Encryption and Key Management.....	11
Datacenter Security.....	12
Data Security and Privacy Lifecycle Management.....	12
Governance, Risk Management and Compliance.....	13
Human Resources.....	13
Identity and Access Management.....	13
Interoperability and Portability.....	14
Infrastructure Security.....	14
Logging and Monitoring.....	15
Security Incident Management, E-Discovery, and Cloud Forensics.....	15
Supply Chain Management Transparency and Accountability.....	16
Threat and Vulnerability Management.....	16
Universal Endpoint Management.....	16
1.1.4 CCM Framework Components.....	17
CCM Control Specifications and Applicability Matrices.....	17
Scope Applicability (Mappings).....	18
The Consensus Assessment Initiative Questionnaire (CAIQ).....	18
Implementation Guidelines.....	19
Auditing Guidelines.....	19
The Continuous Audit Metrics Catalog.....	19
1.1.5 CCM Columns.....	20
a. CCM Controls.....	21
b. Implementation Guidelines.....	23
c. CCM Scope Applicability (Mappings).....	23
d. Consensus Assessments Initiative Questionnaire (CAIQ).....	24
e. Acknowledgments.....	24

f. Change Log.....	24
1.1.6 CCM Target audience.....	24
1.1.7 CCM Compliance Documentation.....	26
1.2 CCM SSRM Implementation Guidelines.....	27
1.2.1 Purpose and Scope.....	27
1.2.2 SSRM Structure and Definitions.....	27
CSP-Owned.....	28
CSC-Owned.....	28
Shared (Independent).....	28
Shared (Dependent).....	28
1.2.3 Target Audience.....	29
1.3 Versioning.....	30

Executive Summary

The Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM) provides fundamental security principles, controls, and controls' criteria to guide cloud service providers (CSPs) and cloud service customers (CSCs) seeking secure implementation, assessment, and management of cloud services security risks. The CSA CCM provides a detailed controls framework aligned with CSA's Security Guidance¹, which states that "the most important security consideration is knowing exactly who is responsible for what in any given cloud project". The CCM now includes a comprehensive structure for delineation and proactive management of the cloud shared security responsibility model (SSRM), with transparency and accountability across the cloud ecosystem.

The Cloud Security Alliance's Cloud Controls Matrix Version 4 (CCM v4.1) includes core security and privacy controls and additional components. These include the CCM Implementation Guidelines (included in this document), the Consensus Assessment Initiative Questionnaire (CAIQ), and the CCM Controls Auditing Guidelines². The CCM v4 also includes useful supporting information for CCM controls. This information includes typical SSRM control ownership assignments and control scope and applicability information, such as: architectural relevance, and mappings to other industry-accepted security frameworks (e.g., ISO/IEC, AICPA, NIST, FedRAMP). These works are regularly reviewed and enhanced by the CSA team.

This document, the CCM implementation guidelines, aims to support the application of CCM controls and provide further guidance and recommendations related to CCM control specifications' implementation. It addresses the critical need to establish clear demarcation lines of security responsibility between the CSP and CSCs, bringing greater clarity and accountability to the implementation process. By assigning security implementation responsibilities within each security control, cloud organizations are enabled to navigate the complexity of shared security effectively. This approach ensures that both CSPs and CSCs understand their roles in implementing controls and fostering a collaborative environment that enhances the overall security posture of the cloud ecosystem.

However, this document is not meant to be a "how-to" manual for the CCM controls implementation. Given the nature of CCM controls, their operationalization will largely depend on the IT/service architecture, the type of technology used, risks faced, applicable regulations, organizational policies, and other significant factors. Therefore, the CSA cannot provide detailed, prescriptive guidance pertinent to every organization and cloud service implementation.

The CCM implementation guidelines are a collaborative product of the volunteer CCM Working Group based on shared CSP and CSC experiences in implementing and securing cloud services and using CCM controls. Workgroup insight covers myriad topics and queries, including how can organizations:

- Implement controls for the first time or improve an existing implementation?
- Guide the implementation of controls across multiple frameworks via CCM mappings?
- Delineate and understand what CSPs and CSCs security responsibilities are in cloud implementations?

¹ <https://cloudsecurityalliance.org/research/guidance/>, accessed on 5 March 2024.

² Released in December 2021.

- Conduct implementation assessments of their CSPs in conjunction with the CAIQ?
- Identify the most effective best practices to include as provisions within their organizational security policy?
- Translate cloud security best practices into contractual provisions with their CSPs?
- Leverage and implement CCM controls within a specific cloud platform or architecture?

1. Introduction

1.1 What is the Cloud Control Matrix

The CCM is a comprehensive cybersecurity control framework developed to provide a set of structured and standardized controls that address security and privacy concerns associated with cloud computing, helping organizations to assess and manage risks related to the adoption of cloud services. At the time of its initial creation in 2010, computing risk management was solely focused on addressing traditional computing infrastructure. The CCM was created to facilitate security and privacy risk management in cloud computing.

The framework is closely aligned with the CSA Security Guidance v4. While the Security Guidance v4 provides high-level cloud security principles, the CCM translates those principles into specific, actionable controls to achieve and maintain security. The CSA encourages organizations to use the CCM as a companion to the CSA Security Guidance to optimize the complementary values of both.

Further, the CCM implementation guidelines (this document) complement the CCM framework by providing SSRM guidelines that help CSPs and CSC delineate their security responsibilities when implementing, managing, and maintaining each of the CCM controls.

The CCM has evolved over time to accommodate changes in technology and security landscapes, making the framework to remain relevant and effective in addressing the dynamic nature of cloud security challenges. The CCM Version 4.1 is the the latest iteration of the framework, featuring 207 control objectives across 17 domains covering all key aspects of cloud technology, and mapped to multiple industry and best practice security standards, regulations, and frameworks.

1.1.1 CCM Purpose and Scope

The primary purpose of the CCM is to drive and facilitate effective and comprehensive security and privacy risks management in the cloud computing ecosystem. Regardless of the type (CSP or CSC) and size of organization (i.e., large corporation vs. small company), or the models of cloud delivery or deployment (IaaS, PaaS, or SaaS), the CCM can be used to define, implement and enforce security requirements and monitor their implementation. The CCM assists companies in translating their internal organizational, operational, and legal stipulations into a standardized set of cloud-relevant policies, procedures, and technical control objectives.

The CCM is also a tool for internal and external assessments or audits. It is designed to be used in alignment with the CAIQ, which provides a set of “yes” or “no” questions that can be answered to determine if the CCM controls are being met. Both documents help auditors understand if an organization follows its internal governance policies and fulfills its legal and regulatory obligations.

For example, based on an internal risk assessment, an organization might identify the need to protect the confidentiality, integrity, and availability of information related to a manufacturing process. The datasets have varying levels of sensitivity and criticality, as they are stored in a cloud database and processed by

several cloud-based applications. The organization can use the CCM to identify specific policy, procedural and technical requirements and define control objectives that will be included in the organizational security program. It uses those control objectives to enforce mandates related to internal users, business partners, and CSPs and monitor adherence to internal policies and external compliance requirements.

Therefore, organizations should implement controls to meet the needs and manage the risks inherent in their unique environment while leveraging the recommendations and guidelines in this document.

1.1.2 CCM Structure

The CCM v4.1 is structured into 17 security domains and 207 controls. The 17 domains were based on CSA’s security guidance document and inspired by major frameworks, such as ISO/IEC 27001:2022. Each CCM domain defines what category a control falls under. CCM was deliberately designed like existing non-cloud leading information security frameworks to leverage familiarity with those existing frameworks.

A&A	Audit & Assurance	IAM	Identity & Access Management
AIS	Application & Interface Security	IPY	Interoperability & Portability
BCR	Business Continuity Mgmt & Op Resilience	I&S	Infrastructure Security
CCC	Change Control & Configuration Management	LOG	Logging & Monitoring
CEK	Cryptography, Encryption & Key Management	SEF	Sec. Incident Mgmt, E-Disc & Cloud Forensics
DCS	Datacenter Security	STA	Supply Chain Mgmt, Transparency & Accountability
DSP	Data Security & Privacy	TVM	Threat & Vulnerability Management
GRC	Governance, Risk Management & Compliance	UEM	Universal EndPoint Management
HRS	Human Resources Security		

Figure 1: List of CCM v4 cloud security domains and their acronyms

1.1.3 CCM Domains Description

The CCM v4 includes 17 cloud security domains. These domains are listed below, along with a description of each one’s unique purpose and use.

Audit and Assurance **A&A**

The Audit and Assurance (A&A) domain consists of six (6) control specifications and enables CSPs and CSCs to inform and establish necessary confidence for critical decision-making, communication, and reporting about key processes—including those control processes encompassed within the CCM—through assessment, verification, and validation activities. This domain is designed to support the CSP and CSC in defining and implementing their respective audit management processes to support audit planning, risk analysis, security control assessment, conclusion, remediation, and reporting as well as their review of and reliance on attestations and supporting evidence.

The SSRM delineates the responsibilities of CSPs and CSCs in implementing A&A controls in a cloud environment. Both CSPs and CSCs are independently responsible for establishing robust audit and assurance policies, conducting regular security assessments, and complying with relevant standards and regulations requirements.

CSPs and CSCs, each implement A&A controls aligned with the SSRM to ensure that both parties independently meet their specific assurance needs over the control processes covered by the CCM.

Application and Interface Security AIS

The Application and Interface Security (AIS) domain consists of eight (8) control specifications and focuses on securing software and interfaces used in the cloud, assisting organizations in identifying and mitigating risks to cloud landscapes in the application's design and development phase. Implementing cloud security controls in this domain is crucial for a CSP to ensure the integrity, confidentiality, and availability of the applications and interfaces within their cloud environment.

In the SSRM, CSPs are responsible for securing the underlying infrastructure offering secure applications and APIs following secure coding practices, establishing application security baselines, conducting automated application security testing and ensuring the availability and maintenance of secure runtime environments. The CSCs are responsible for securing their applications and interfaces, establishing an application security baseline, and ensuring the proper configuration of security settings, upgrades, and secure integration of new systems and new versions of systems and applications, following best practices depending on the cloud deployment model.

Each party benefits from a secure cloud environment, reducing the risk of application vulnerabilities and ensuring the confidentiality and integrity of their data. Collaboration fosters communication, enabling proactive threat response and faster incident resolution.

Business Continuity Management and Operational Resilience BCR

The Business Continuity Management and Operational Resilience domain consists of eleven (11) control specifications and focuses on safeguarding critical business processes, infrastructure, and services, minimizing the impact of disruptions, and ensuring business continuity in the face of potentially disruptive events. Implementation of cloud security controls in this domain is paramount for both CSPs and CSCs to ensure uninterrupted service delivery and maintain operational resilience.

CSPs and CSCs play distinct but interconnected roles in ensuring infrastructure resilience and business continuity in the cloud environment. CSPs are responsible for planning, developing, and implementing robust technologies, services, policies, procedures, and processes controlling continuity and operational resilience of the cloud and cloud services and for transparently communicating the resilience and recovery capabilities of their services to CSCs. CSCs are responsible for assessing and managing potential business disruption risks associated with their data and other resources and assets hosted in the cloud. Based on risk analyses, CSCs should formulate and implement robust business continuity strategies tailored to their specific requirements and priorities, including developing and maintaining their own comprehensive business continuity plans and procedures to be followed in the event of a disruption.

Through fulfilling their respective responsibilities and collaboration, both CSPs and CSCs contribute to maintaining resilient and reliable cloud operations that enable organizations to continue business operations even in the face of disruptions.

Change Control and Configuration Management CCC

The Change Control and Configuration Management domain incorporates nine (9) controls and focuses on managing and securing changes to the cloud environment, ensuring that modifications do not introduce vulnerabilities or compromise the security of systems in the cloud environment. Effectively managing changes is vitally important to ensure a stable and secure cloud service is maintained, both for the CSPs and the CSCs.

Where the service is offered as Software as a Service (SaaS) the CSP will typically have assumed responsibility for establishing and maintaining a secure change management process, ensuring configuration baselines are established, change risk assessments are conducted and ensuring all changes are subject to appropriate authorization, prior to change implementation within the cloud infrastructure. For Infrastructure as a Service (IaaS), the CSP will typically provide only underlying networking and infrastructure to base operating system level at maximum, so change management for all operating system level and application level configuration needs to be designed, implemented, validated and managed by the CSC. For Platform as a Service (PaaS), the CSP provides underlying infrastructure and operating system configuration to the application layer, so the CSC is required to design the application configuration and implementation, so a suitable change management process must be established by the CSC to ensure the required application is securely configured to obtain the desired outcome without introducing vulnerabilities and monitor for any deviations from established configuration baselines.

Both CSPs and CSCs leverage the CCM controls to ensure a secure cloud environment is configured and maintained to established baselines to support agreed service requirements. This domain ensures IT asset configurations are only modified to an approved baseline after the relevant CSP or CSC change management authority has approved the configuration change.

Cryptography, Encryption and Key Management CEK

The Cryptography, Encryption and Key Management (CEK) domain consists of twenty-one (21) control specifications that aim to protect CSCs' data by employing cryptographic techniques, encryption, and key management practices. The CEK domain plays a crucial role in ensuring compliance with encryption and key management requirements of various regulatory standards, facilitating the confidentiality and integrity of sensitive information in the cloud environment.

In the SSRM, the CSPs typically oversee the governance of cryptography, encryption, and key management, while ensuring that the scope definition aligns with industry best practices and regulatory requirements. The CSPs are responsible for managing the underlying infrastructure and cryptographic services, providing secure key storage and encryption capabilities. The CSCs are accountable for defining and assigning roles and responsibilities within their specific applications and data, encrypting sensitive data prior to upload, managing their own encryption keys, as well as implementing cryptographic risk and change management processes in their specific environment.

Collaboration between the CSPs and CSCs for the implementation of CEK security controls provides mutual benefits for both parties. For the CSPs, it facilitates the confidentiality and integrity of CSCs data, enhancing the overall security and compliance of their cloud services. For the CSCs, collaboration ensures that their specific cryptographic requirements are met.

Datacenter Security **DCS**

This domain consists of eighteen (18) control specifications that are essential for CSPs to secure the physical infrastructure and environment of the CSP that hosts the data and applications of the CSCs. This includes safeguarding physical assets, such as physical infrastructure and equipment against security threats such as unauthorized access and environmental hazards.

In the SSRM, CSPs are exclusively responsible for securing the datacenter's physical infrastructure, environmental controls, and overall facility security. The CSCs are not responsible for datacenter security, nevertheless, in the context of A&A domain should verify the CSPs' compliance with DCS controls.

Data Security and Privacy Lifecycle Management **DSP**

The Data Security and Privacy Lifecycle Management (DSP) domain features nineteen (19) controls on privacy and data security. These controls are not industry or sector-specific and are not focused on a particular country or regulation. However, these controls have been developed by considering the common elements and requirements of major privacy regulations. They are generally applicable to organizations worldwide and are expected to serve as a valuable baseline—with the caveat that some organizations operating in some locations or sectors may have to implement supplemental data protection controls.

DSP controls cover the complete data lifecycle, from creation to disposal, including data privacy, data classification, inventorying, retention and disposal procedures according to all applicable laws and regulations, standards, and risk level. Controls in the DSP help both CSPs and CSCs in protecting relevant data & complying with data protection laws and regulations.

Under the SSRM, the CSP is responsible for the security "Of" the cloud and provides to the CSC capabilities for secure data storage, access and disposal practices. The CSC, on the other hand, is responsible for securing the data they store or process "In" the cloud, including the classification of data, and leveraging the CSP's provided capabilities for data protection such as encryption, and specifying levels of data access, while ensuring compliance with data privacy regulations.

DSP controls' implementation offers substantial benefits, as it enhances the overall security and privacy of the data in the cloud. The shared responsibility fosters a robust and compliant cloud environment, beneficial for both parties.

Governance, Risk Management and Compliance **GRC**

The Governance, Risk Management, and Compliance (GRC) domain comprises eight (8) control specifications that help CSPs and CSCs ensure their information governance and associated enterprise risk management (ERM), information security management, and compliance management programs adequately address cloud offerings and concerns.

Typically, CSPs and CSCs are independently responsible for implementing their respective governance, risk, and compliance controls to cover their management and operations, including those for their cloud-based products, services, assets, processes, and providers. The establishment of a GRC program is fully internal and unique to each organization.

Implementing GRC security controls helps cloud organizations effectively direct and control their resources and capabilities by providing a structured governance framework for managing risks, ensuring compliance with regulations, and aligning security practices with their business objectives.

Human Resources **HRS**

The Human Resources (HRS) security domain utilizes thirteen (13) controls that aid cloud organizations in managing the risk associated with insider threats and ensures that personnel handling sensitive data are trustworthy and properly trained. Effective HRS measures safeguard against unauthorized access and data breaches caused by human factors, thus maintaining the overall security posture.

In SSRM, both CSPs and CSCs have roles and responsibilities in independently implementing HRS security controls. Both are typically responsible, however independently, for conducting background checks, providing ongoing security training to their employees, and ensuring that their staff are aware of the cloud security risks and security best practices.

Implementing HRS controls allows cloud organizations to secure their services by employing well-trained and vetted personnel. This mitigates the risk of security incidents stemming from human error or malicious intent.

Identity and Access Management **IAM**

The Identity and Access Management (IAM) domain features fifteen (15) control specifications for helping both CSPs and CSCs adhering to security best practices in managing identities and access to security functions and data in the cloud environment. Best practices such as the principle of least privilege, segregation of duties, multi-factor authentication, role based and attribute based access control are central to managing access to cloud resources.

Both the CSPs and CSCs share responsibilities to establish secure access to the cloud environment. The CSPs are typically responsible for providing strong identity and access capabilities, functions, controls, and related mechanisms to the CSCs. The CSCs are typically responsible for defining user roles and access permissions based on the principle of least privilege, appropriately enforcing strong authentication mechanisms, managing the full lifecycle of identities and their levels of access—including user access

provisioning, modification, and revocation for the cloud services—and monitoring user activity to identify and respond to any suspicious behavior.

Collaboration between CSPs and CSCs to implement effective IAM capabilities assures that necessary controls are implemented to protect CSCs data from unauthorized access.

Interoperability and Portability **IPY**

The CCM's Interoperability and Portability (IPY) domain has four (4) control specifications to address interoperability and portability in the cloud environment. Implementing robust interoperability and portability controls facilitates the safe and secure exchange of data across multiple platforms and CSPs, enabling CSCs to avoid vendor lock-in and fostering an environment where interoperability and portability are not hindered by security concerns.

Both CSPs and CSCs, independently share responsibilities in ensuring interoperability and portability within the cloud ecosystem. The CSPs are typically responsible for implementing standardized communication protocols, ensuring secure communication channels, maintaining cross-platform compatibility, standardized data formats, and common data-processing and data exchange protocols. The CSCs are responsible for understanding and using tools provided by the CSPs for secure data backup, transfer, and restore, including using interoperable data encryption. The CSCs should also understand management, monitoring and reporting interfaces provided by the CSPs and the integration of those interfaces among multiple environments. Both the CSPs and CSCs are jointly responsible for documenting data portability contractual obligations, such as defining data ownership and migration procedures.

Shared commitment to interoperability and portability from both CSPs and CSCs is important for building a safe, secure and flexible cloud ecosystem.

Infrastructure Security **I&S**

The Infrastructure Security (I&S) domain consists of nine (9) controls that guide CSPs and CSCs in implementing controls to secure infrastructure and virtualization technologies. Infrastructure encompasses all hardware, software, networks, facilities, etc., required to deliver IT services. Virtualization technologies use software to create an abstraction layer over computer hardware that allows the hardware elements (such as processors, memory, storage, etc.) to be divided into virtual computers.

Both CSPs and CSCs are typically responsible for implementing the I&S controls. CSPs are typically responsible for securing the underlying infrastructure, including the platform (hypervisor, VMs and Host OS) and network virtualization technologies, implementing network segmentation and segregation and providing capabilities to the CSC for capacity and resource planning. The CSCs are typically responsible for securing their allocated resources within the virtualized environment such as hardening the guest operating systems, applying security patches, disabling unnecessary services, and managing access to the platforms and control plane user interfaces.

Infrastructure and virtualization technologies are fundamental building blocks of cloud computing, collaboration between the CSPs and the CSCs in the implementation of infrastructure and virtualization security controls helps ensure the security of workloads running in the cloud.

Logging and Monitoring **LOG**

Logging and monitoring domain uses fourteen (14) controls that enable CSPs and CSCs to collect, store, analyze and report on the activities and events that occur in their cloud environment. This in turn helps to detect and respond to security incidents, operational issues and system anomalies, comply with regulatory requirements, audit and verify the effectiveness of their security controls, and improve their security posture and performance.

Both the CSPs and CSCs are typically responsible for implementing logging and monitoring controls. The CSPs are typically responsible for logging and monitoring of the cloud infrastructure, including network and system-level operations. Meanwhile, CSCs are typically responsible for monitoring and logging within their deployed applications and services, ensuring that their specific security requirements are met.

Collaboration between the CSPs and the CSCs in the implementation of logging and monitoring controls ensures enhanced visibility, accountability and transparency of cloud operations. Logging and monitoring can help them to identify and mitigate security risks, optimize their cloud usage and performance, and demonstrate compliance with relevant standards and regulations.

Security Incident Management, E-Discovery, and Cloud Forensics **SEF**

The Security Incident Management, E-Discovery, and Cloud Forensics (SEF) domain has ten (10) control specifications that are essential for effectively managing and responding to security incidents, conducting e-discovery, and performing forensics in the cloud. The controls help CSPs and CSCs for timely detection, analysis, and response to security incidents, minimizing the impact on business operations.

In the SSRM, CSPs and CSCs are typically responsible to develop well-defined incident response plans, establish clear roles and responsibilities, implement metrics, report incidents to relevant stakeholders, and escalate procedures for addressing security incidents efficiently. A critical aspect of CSP and CSC collaboration is triaging potential security incidents that often requires a joint effort where the CSP can provide valuable insights into potential sources or root causes of the security event, while the CSC can contribute information specific to their data, configuration, applications, and user activity.

Collaboration between CSPs and CSCs in implementing SEF controls leads to a mutually effective incident management and forensics capability, which ensures quicker recovery from incidents and facilitates compliance with legal and regulatory requirements.

Supply Chain Management Transparency and Accountability **STA**

The Supply Chain Management, Transparency, and Accountability (STA) domain features sixteen (16) control specifications to aid cloud parties in delineating a broad set of supply chain risk management controls, such as managing the SSRM between the CSPs and the CSCs. These controls enable third-party providers to employ appropriate security measures to protect the confidentiality, integrity, and availability of information, applications, and services across the full technology stack. These controls also help manage security and regulatory compliance across the supply chain.

In the SSRM, the CSPs are responsible for securing and managing their supply chain and for ensuring transparency in their operations. CSCs must assess and understand the risks associated with their selected CSPs and their supply chain vendors and ensure their requirements are met.

Collaboration between CSPs and CSCs in implementing STA controls leads to transparency and accountability between the parties and a more robust and secure supply chain. For CSCs, collaboration ensures that their specific requirements and concerns regarding supply chain security are addressed.

Threat and Vulnerability Management **TVM**

The Threat and Vulnerability Management (TVM) domain consists of twelve (12) control specifications to help both CSPs and CSCs to proactively identify and mitigate security threats and vulnerabilities in the cloud environment that may evolve and impact assets, security architectures, designs, and solution components.

In the SSRM, both CSPs and CSCs are typically responsible for implementing TVM security controls. The CSPs are typically responsible for the identification, assessment, reporting, and prioritization remediation of vulnerabilities on the host infrastructure, network devices, virtualization technologies, operating systems, platform applications such as databases and web applications. On the other hand, the CSCs are responsible for the identification, assessment, reporting, and prioritization remediation of vulnerabilities relating to applications/APIs security settings and access misconfigurations.

Collaboration between the CSPs and the CSCs in the implementation of TVM controls strengthens the overall cloud security posture by addressing vulnerabilities across the entire cloud infrastructure, from the underlying platforms to the deployed applications.

Universal Endpoint Management **UEM**

The Universal Endpoint Management (UEM) domain consists of fourteen (14) control specifications and focuses on implementing controls to mitigate the risks associated with endpoints, including mobile devices. The risk with mobile computing and endpoint security mainly relates to user behavior and the awareness (or lack of awareness) of a company's approach to acceptable use of devices and technologies (e.g., managed vs. unmanaged, enterprise-owned vs. personal).

Both CSPs and CSC are typically and independently responsible for implementing UEM security controls. The CSPs are primarily responsible for endpoint management capabilities such as maintaining an inventory of all endpoints, approving services and applications acceptable for use by endpoints, implementing security measures like automatic lock screens, firewalls, and anti-malware detection, and

utilizing prevention technologies, storage encryption, and data loss prevention technologies. Meanwhile, CSCs are responsible for securely managing their devices, ensuring they comply with the security policies set by the CSPs, for protecting their data.

Collaboration between the CSPs and the CSCs in the implementation of UEM controls strengthens the overall cloud security posture of endpoints used to access cloud resources.

1.1.4 CCM Framework Components

Along with the core 207 security and privacy controls, the CCM v4. includes additional tools, such as:

- CCM Control Specifications and Applicability Matrices
- Scope Applicability (Mappings)
- Consensus Assessment Initiative Questionnaire (CAIQ)
- Implementation Guidelines (included in this document)
- Auditing Guidelines
- The Continuous Audit Metrics Catalog

CCM Control Specifications and Applicability Matrices

The CCM control specifications are mapped to the controls applicability matrix, which is comprised of three main groups:

- Typical Control Applicability and Ownership
- The architectural relevance - cloud stack components
- The organizational relevance

The typical control applicability and ownership matrix describes standard SSRM control ownership and applicability for all controls for the three main cloud service models: IaaS, PaaS, and SaaS. Common SSRM ownership designations allocate responsibilities typical for implementing a given CCM control between a CSP and a CSC, as required by control STA-04. Some controls are clearly the province of IaaS providers (e.g., data center security controls), whereas other controls are applicable across all service models (e.g., identity and access management). This CCM matrix describes the applicability of each control to the three cloud service models, helping users understand what is relevant in specific cases.

The architectural relevance group indicates the architectural relevance of each CCM control per cloud stack component from the perspective of the CSA *Cloud Reference Model*. The section focuses on numerous elements, including physical, network, compute, storage, application, and data. In addition, because the CCM is mapped to existing security controls specifications from various legal and regulatory frameworks—and that same matrix is mapped to the security capabilities of the architecture—enterprises can easily assess which capabilities comply with applicable regulations and best-practice frameworks.

The organizational relevance group indicates the connection between each CCM control and its implementation by the respective cloud relevant functions within an organization. The functions included

are: "Cybersecurity", "Internal Audit", "Architecture Team", "Software Development Team", "Operations", "Legal/Privacy", "Governance/Risk/Control", "Supply Chain Management", and "Human Resources".

Scope Applicability (Mappings)

An important CCM aspect is that it maps to other security standards, regulations, and frameworks. When the CCM was created, there were already many different information security standards, best practices, and regulations in existence (e.g., ISO 27001: 2022, PCI DSS, NERC CIP, BITS, BSI). Many companies already had their internal structures and frameworks set up and aligned with those standards.

The CSA wanted to provide cloud sector-specific controls while ensuring that organizations had clear paths to connect their existing control frameworks and programs with the cloud-relevant controls included in the CCM. Therefore, the CSA built all the controls created in the CCM as an extension of existing framework controls. The CSA constructed a mapping, or a linkage, between a framework control (e.g., ISO 2700: 2022) and the CCM to realize this ambition. The CCM then builds on the framework to provide a control specific to the cloud sector—and then takes it one step further by ensuring controls link to a particular area within a cloud architecture. Then, the CCM helps identify if a specific control is relevant for IaaS, PaaS, or SaaS. Because the CCM makes links through mapping, it provides an initial internal controls system that identifies which controls organizations should enact to further a cloud journey and implementation processes.

The Consensus Assessment Initiative Questionnaire (CAIQ)

The CAIQ provides cloud customers and auditors with questions for CSPs about security posture, adherence to CSA best practices (CCM and the CSA Security Guidance) and customer SSRM responsibilities. The CAIQ is a companion document designed to support better adoption of the CCM. While the CCM defines the control specification and implementation guidelines, the CAIQ defines questions to evaluate and inform implementation. In addition, the CAIQ (and the *CSA STAR Registry*) should be used by CSPs to provide SSRM ownership and customer security responsibility guidance to current and prospective CSCs per CCM controls STA-01 through STA-06.

The relationship between a CCM control and CAIQ questions is often one to many. This is by design because the CCM is based on 207 controls, whereas the latest version of the CAIQ (version 4) has 283 questions. Depending on the nature and the complexity of the CCM control, there may be one or several questions posed to verify the implementation of a certain control.

The CAIQ, similar to the CCM, comes in a spreadsheet format with a structure similar to the CCM. The CAIQ includes columns for CSPs to respond to CAIQ questions ("Yes," "No," or "NA") while specifying SSRM ownership of CCM controls the CAIQ question pertains to. The CAIQ also includes columns for CSPs to describe how they meet their portions of the controls and any associated customer security responsibilities. Cloud service providers should delineate SSRM ownership, explain how they meet control requirements, and clarify customer security responsibilities at the question level.

The CAIQ and the *CSA STAR Registry* provide a framework and forum for CSPs to provide useful information that current and prospective customers can use to evaluate how controls have been

implemented. Furthermore, these tools enable providers to delineate their implementation of the SSRM for customer benefit.

Implementation Guidelines

The main goal of CCM Implementation Guidelines is to provide further guidance and recommendations on CCM controls' implementation. This document is a collaborative product based on CSP and CSC experiences implementing and securing cloud services while using CCM controls under the Shared Security Responsibility Model.

Under the SSRM, CSPs and CSCs are tasked with specific shared security responsibilities with respect to "Who" is responsible for doing "What" in the shared cloud infrastructure. This document provides SSRM specific guidance for both CSPs and CSCs delineating such responsibilities at the control specification level.

However, the guidelines are not meant to be a "how-to" manual for CCM control implementation. Given the comprehensive nature of the CCM controls, their operationalization largely depends on the nature of the cloud service and its architecture, the types of technology used, applicable risks and regulations, organizational policies, the threat environment, and other significant factors. Therefore, CSA cannot provide detailed, prescriptive guidance applicable to every organization and cloud service controls' implementation.

Auditing Guidelines

The *CCM v4 Auditing Guidelines (AGs)* are tailored to the control specifications of each of the 17 cloud security domains of the *Cloud Control Matrix version 4 (CCM v4.1)*. The guidelines represent a new component of CCM v4 that did not exist previously in CCM v3.0.1.

The AGs aim to facilitate and guide a CCM audit. Auditors are provided with a set of assessment guidelines per CCM v4 control specifications. These guidelines seek to improve the controls' auditability and help organizations more efficiently achieve compliance (with either internal or external third-party cloud security audits).

The auditing guidelines are not exhaustive or prescriptive by nature. Rather, they represent a generic guide through recommendations for assessment. Auditors must customize the descriptions, procedures, risks, controls, and documentation. These elements must conform to organizational- specific audit work programs and service(s) in the scope of the assessment to address the specific audit objectives.

The CSA auditing guidelines were released in December 2021.

The Continuous Audit Metrics Catalog

A metric is a standard for measurement that defines the rules for performing the measurement and understanding the results of a measurement (ISO/IEC 19086-1). In the context of cloud computing, there is a growing interest in defining metrics that can be used to evaluate the security of an information system, potentially in real-time.

Security metrics can be used for several purposes:

- *Measuring the effectiveness of an information system.* Using metrics allows organizations to assign qualitative or quantitative values to various attributes of an information system. By carefully selecting attributes that reflect the implementation of security control, metrics can be used to measure the effectiveness of these controls.
- *Increasing the maturity of an organization governance and risk management approach.* Organizations that select and implement security metrics are required to adopt the necessary tools to notably categorize their assets and measure associated security attributes. This work is not trivial, so the ability to conduct it illustrates that the organization has reached a certain level of maturity in information security management.
- *Increasing transparency and accountability, enabling continuous compliance.* Organizations that adopt metrics can provide visibility to the relevant stakeholders into their security and privacy practices and better explain and justify their Service Level Agreement. Metrics could even be used as a foundation for a continuous certification scheme that goes beyond what traditional point-in-time certifications offer today.

The Continuous Audit Metrics Catalog is the product of the work conducted by industry experts in the CSA Continuous Audit Metrics Working Group. The catalog does not aim to be exhaustive or complete; and the initial release aims to offer support for those organizations seeking for a more systematic evaluation of the efficiency and effectiveness of the CCM controls implementation.

The proposed metrics aim to support internal CSP governance, risk, and compliance (GRC) activities and provide a helpful baseline for service-level agreement transparency. Additionally, these metrics might be integrated within the STAR Program in the future, providing a foundation for continuous certification.

The *CCM Implementation Guidelines* presented in this document suggest the use of metrics to ascertain the correct implementation of several controls. Moreover, CSA defined the catalog of cloud security metrics³ that are mapped to the *Cloud Control Matrix version 4 (CCM v4)*.

1.1.5 CCM Columns

The CCM V4 spreadsheet, as of the date of publication of this document, includes six tabs:

- Introduction.
- CCM Controls.
- Implementation Guidelines.
- CCM Scope Applicability (Mappings).
- Consensus Assessments Initiative Questionnaire (CAIQ).
- Acknowledgments.

³ <https://cloudsecurityalliance.org/artifacts/the-continuous-audit-metrics-catalog>, accessed on 5 March 2024.

a. CCM Controls

This is the core of the CCM V4. It includes 207 controls structured in 17 domains. Each control is described by a:

- Control Domain: the name of the domain each control pertains to.
- Control Title: The control's title.
- Control ID: The control's identifier.
- Control Specification: The control's requirement(s) description.

CCM™ CLOUD CONTROLS MATRIX v4.1.0			
Control Domain	Control Title	Control ID	Control Specification
Audit & Assurance - A&A			
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.

Figure 2: Snapshot of CCMv4 'Audit & Assurance' domain's control specification.

In addition, this tab includes the following sections (groups of columns):

- **The Typical Control Applicability and Ownership matrix.** These columns describe the standard SSRM control ownership and applicability for all controls for the three main cloud delivery models: IaaS, PaaS, and SaaS. Common SSRM ownership designations allocate responsibilities typical for implementing a given CCM control between a CSP and a CSC. The matrix indicates whether a control's responsibility is usually "CSP-Owned", "CSC-Owned", or "Shared" between the CSP and CSC (as required by control STA-04). The SSRM control ownership varies from service to service, depending on the cloud service model and the implementation of each specific cloud service. Accordingly, CSPs should provide detailed, service-specific SSRM guidance to facilitate secure customer service implementations. Version No. 4 of the CAIQ has been enhanced to provide a framework and forum for CSPs to document and share this crucial information with current and prospective customers (per CCM controls STA-01 - STA-06).

					Typical Control Applicability and Ownership		
Control Domain	Control Title	Control ID	Control Specification	CCM Lite	IaaS	PaaS	SaaS
Audit & Assurance - A&A							
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.	No	Shared	Shared	Shared

Figure 3: Snapshot of CCMv4 'Audit & Assurance' domain and control applicability per IaaS-PaaS-SaaS.

- The Architectural Relevance and Cloud Stack Components matrix.** These columns indicate the architectural relevance of each CCM control—per cloud stack component—from the perspective of the CSA *Cloud Reference Model*. The section focuses on the following components: "Physical", "Network", "Compute", "Storage", "App (Application)", and "Data."

The relevance box associated with each component is marked as "TRUE" if the control is relevant to a component and "FALSE" if not.

The architectural relevance represents a high-level simplification, and CCM users should revise those attributions depending on their specific cloud environments and technologies used.

					Architectural Relevance - Cloud Stack Components					
Control Domain	Control Title	Control ID	Control Specification	CCM Lite	Phys	Network	Compute	Storage	App	Data
Audit & Assurance - A&A										
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.	No	TRUE	FALSE	FALSE	FALSE	TRUE	TRUE

Figure 4: Snapshot of CCMv4 'Audit & Assurance' domain and control architectural relevance

- The Organizational Relevance matrix.** This group of columns indicates the relevance between each CCM control and its implementation by the respective cloud relevant functions within an organization. The functions included are: "Cybersecurity", "Internal Audit", "Architecture Team", "SW (Software) Development Team", "Operations", "Legal/ Privacy", "GRC (Governance/Risk/Control) Team", "Supply Chain Management", and "HR (Human Resources)."

The "relevance box" associated with each component is marked as "TRUE" if the control is relevant to a component and "FALSE" if not.

					Organizational Relevance								
Control Domain	Control Title	Control ID	Control Specification	CCM Lite	Cybersecurity	Internal Audit	Architecture Team	SW Development	Operations	Legal/Privacy	GRC Team	Supply Chain Management	HR
Audit & Assurance - A&A													
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.	No	FALSE	FALSE	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	FALSE

Figure 5: Snapshot of CCMv4 controls organizational relevance columns.

b. Implementation Guidelines

This tab includes the implementation guidelines which provide suggestions, recommendations and examples of how to implement the CCM controls in alignment with the Shared Security Responsibility Model.

c. CCM Scope Applicability (Mappings)

This tab includes the mappings between CCM V4 and numerous standards (ISO 27001/2/17/18) and best practices (CIS v8.0) control sets relevant to cloud computing.

For each standard, CCM V4 is mapped to include the following three columns:

- Control Mapping. The indication of which control(s) in the target standard (e.g., ISO27001: 2022) corresponds to the CCM control.
- Gap Level. The gap level a control (or controls) in the target standard has when compared with the CCM control. The gap levels used are:
 - No Gap: In case of full correspondence.
 - Partial Gap: If the control(s) in the target standard does not fully satisfy the corresponding CCM control's requirements.
 - Full Gap: If there is no control in the target standard to fulfill the corresponding CCM control's requirements.
- Addendum. The suggested compensating control organizations could implement to cover the gap between the control in the target standard and the corresponding CCM control.

CCM [™] CLOUD CONTROLS MATRIX v4.0.10						
				ISO/IEC 27001:2022, 27002:2022		
Control Domain	Control Title	Control ID	Control Specification	Control Mapping	Gap Level	Addendum
Audit & Assurance - A&A						
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually.	27001: 5.1 27001: 5.2 27001: 7.3 27001: 7.4 27001: 7.5 27001: 9.1 27001: 9.2 27001: 9.3 27001: A.5.1 27001: A.5.4 27001: A.5.37	Partial Gap	Missing specification(s) in ISOs: 'at least annually (Review)'.

Figure 6: Snapshot of a CCMv4 control mapping to ISO standards illustrating the relevant columns.

d. Consensus Assessments Initiative Questionnaire (CAIQ)

This tab includes the questionnaire associated with CCM controls, commonly known as CAIQ. The CAIQ consists of 283 questions structured in the 17 domains of the CCM. Each question is described in the following manner:

- Question ID: the question's identifier.
- Question: the description of the question.

CAIQ						
CONSENSUS ASSESSMENTS INITIATIVE QUESTIONNAIRE						
Control Domain	Control Title	Control ID	Control Specification	Question ID	Consensus Assessments Question	CAIQ Lite
Audit & Assurance - A&A						
Audit & Assurance	Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually.	A&A-01.1	Are audit and assurance policies, procedures, and standards established, documented, approved, communicated, applied, evaluated, and maintained?	No
				A&A-01.2	Are audit and assurance policies, procedures, and standards reviewed and updated at least annually?	No
	Independent Assessments	A&A-02	Conduct independent audit and assurance assessments according to relevant standards at least annually.	A&A-02.1	Are independent audit and assurance assessments conducted according to relevant standards at least annually?	Yes
	Risk Based Planning Assessment	A&A-03	Perform independent audit and assurance assessments according to risk-based plans and policies.	A&A-03.1	Are independent audit and assurance assessments performed according to risk-based plans and policies?	Yes
	Requirements Compliance	A&A-04	Verify compliance with all relevant standards, regulations, legal/contractual, and statutory requirements applicable to the audit.	A&A-04.1	Is compliance verified regarding all relevant standards, regulations, legal/contractual, and statutory requirements applicable to the audit?	Yes

Figure 7: Snapshot of a CCMv4 control and corresponding CAIQv4 assessment questions.

e. Acknowledgments

This tab acknowledges the experts who contributed to CCM v4.1's development.

f. Change Log

This tab captures the changes made to CCM v4.

1.1.6 CCM Target audience

The CCM was created to help cloud customers, cloud service providers, auditors and consultants.

Cloud Service Customers (CSC): The CCM allows cloud customers to build a detailed list of requirements and controls they want their CSP to implement as part of their overall third-party risk management and procurement program. It also helps normalize security expectations, provides a cloud taxonomy, and improves understanding of the security measures implemented in the cloud supply chain. Because the actors within a cloud supply chain are independent organizations, each has its own way of expressing and

representing its security requirements. Each actor might use a different vocabulary or apply policies that differ from others. It is vital to define a taxonomy—or a set of agreed-upon terms—to standardize the various languages in such a context. That is why CCM plays a critical role and why more overarching frameworks are necessary to simplify interoperability.

Cloud customers can use the CCM controls to do the following:

- Map organizational, operational and legal requirements to control objectives.
- Build an operational cloud risk management program.
- Build a third-party risk management program.
- Build an internal and external cloud audit plan.

When organizations build cloud risk management programs, the CCM can help measure, assess, and monitor risks associated with CSPs or particular services. The CCM allows customers to understand the gaps between their own security needs and CSP security capabilities. Customers can then use the CCM to identify compensating controls to close gaps between organizational needs and provider offerings.

When building a third-party risk management program, the CCM allows customers to assess a cloud service during the overall service lifecycle. For example, it can be used to evaluate the service before its acquisition, compare offerings from different CSPs, and monitor alignment with internal requirements during the service execution.

When organizations build cloud risk management programs, the CCM can help measure, assess, and monitor risks associated with CSPs or particular services. The CCM allows customers to understand the gaps between their own security needs and CSP security capabilities. Customers can then use the CCM to identify compensating controls to close gaps between organizational needs and provider offerings.

When building a third-party risk management program, the CCM allows customers to assess a cloud service during the overall service lifecycle. For example, it can be used to evaluate the service before its acquisition, compare offerings from different CSPs, and monitor alignment with internal requirements during the service execution.

Cloud service providers (CSPs): The CCM serves multiple purposes for CSPs. First and foremost, it offers cloud-specific, industry-validated best practices CSPs can follow to guide internal security programs. In addition, it provides standardized language CSPs can use to communicate with customers and business partners.

The CCM mapping feature allows CSPs to demonstrate alignment with other recognized international, national, and industry frameworks and compliance with the CSA *STAR* program—which relies on the CCM as one of its foundational frameworks (see Chapter 9 for more details). In addition, the CSA *STAR* program enables organizational transparency and reduces the number of security questionnaires they must provide for customers. These benefits can be realized when organizations complete the CCM extended question self-assessment (the CAIQ) and submit it to the CSA *STAR Registry*—a free, publicly accessible registry documenting CSP-provided security controls.

CSPs can use CCM controls to:

- Build an internal security program based on mature and industry-recognized best practices.
- Facilitate communication and interoperability with business partners and customers.
- Demonstrate commitment to security and transparency about security postures.
- Streamline compliance by leveraging mapping between CCM controls and the controls in other international, national, and industry frameworks.
- Reduce time and effort spent addressing customer questionnaires.
- Demonstrate commitment to security to regulators by adhering to the CSA STAR program (see Chapter 9).
- Build a cloud internal and external audit plan.

Auditors and Consultants: Auditors and consultants can use the CCM to guide clients in designing, planning, and executing activities dedicated to cloud customers and CSPs.

Consultants and auditors can leverage CSA resources to:

- Help organizations assess their cloud maturity.
- Establish controls aligned with the CCM.
- Compare organizations with market peers through benchmarking.

1.1.7 CCM Compliance Documentation

To provide an organizational record and prepare for compliance audits, CCM users should focus on documenting compliance with the CCM V4 controls that they are responsible for in whole or in part under the Shared Security Responsibility Model (SSRM) that always exists between the Cloud Service Provider (CSP) and their Cloud Service Customers (CSC).

CCM users should start by developing or assembling high level CCM compliance and SSRM control applicability and implementation summary documentation as appropriate for their cloud role, e.g. as a Cloud Service Provider (CSP) or Cloud Service Customer (CSC).

- For CSPs a fully completed Consensus Assessment Initiative Questionnaire v4 (CAIQ v4)⁴ will generally be a good starting point. Completed CAIQ questionnaires can be published in the CSA's Security, Trust, Assurance, and Risk (STAR) Registry⁵ and/or maintained internally by the CSP using the Excel questionnaire template. Fully completed questionnaires will include the optional CSP Implementation Description and CSC Responsibilities (Optional/Recommended) columns.
- For CSCs, the CSA does not have a specific questionnaire or compliance documentation template. However, organizations should have (or develop) some form of CCM compliance documentation to incorporate SSRM customer security responsibilities (as delineated by the CSP per CCM STA control requirements). For example, some CSCs will tailor a version of the CCM controls spreadsheet and/or a copy of their CSP's CAIQ questionnaire to incorporate customer

⁴ <https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4>, accessed on 5 March 2024.

⁵ <https://cloudsecurityalliance.org/star/registry>, accessed on 5 March 2024.

security control response information (e.g., adding additional columns to standard artifacts). Alternatively, CSCs may utilize an internal GRC application to assemble similar details. This compiled data can generate appropriate reports for compliance review and audit purposes.

In addition to high-level SSRM control implementation summary information, more detailed supporting documentation (e.g., technical designs, process and procedure documentation, and evidence of compliance) should be developed for specific control domains and individual controls (as appropriate). This documentation should be based on the detailed guidelines underscored in this document and an organization's security auditor or assessor requirements.

1.2 CCM SSRM Implementation Guidelines

This section introduces the purpose and scope of the implementation guidelines.

1.2.1 Purpose and Scope

The document contains implementation guidelines tailored to the control specifications for each of CCM's 17 cloud security domains. The implementation guidelines aim to support organizations and provide guidance for implementing every CCM security and privacy control specification.

The implementation guidelines provide clarity and transparency between CSPs and CSCs with respect to the responsibilities for implementing and managing security for their cloud infrastructure and services. This is important for establishing trust and accountability to meet contractual obligations. The SSRM Implementation Guidelines mitigate the risks associated with misunderstandings or blind presumptions about cloud security responsibilities between the CSPs and CSCs.

The guidelines are technology/ vendor agnostic, meaning they are not tailored to a specific technology but defined at the same high level as each CCM control specification. However, they include more details regarding best practices for implementing such controls, as recommended by cloud organizations.

The implementation guidelines are not exhaustive nor prescriptive. Instead, they represent a generic guide highlighting recommendations. Therefore, security practitioners must customize the descriptions, procedures, risks, controls, and documentation and tailor these to their risk management programs and cloud service(s) (in the scope of the risk assessment) to address specific security objectives and implementations.

1.2.2 SSRM Structure and Definitions

The SSRM expressions "CSP-Owned", "CSC-Owned" and "Shared Independent/Dependent" are introduced within the implementation guidelines and within each CCM control specification in aid to both CSPs and CSCs comprehend what is the "typical" control ownership and implementation responsibility per each party.

The meaning of these SSRM expressions is better explained here below:

Control Ownership CSP-Owned	Control ownership and implementation responsibility is owned by the CSP. The CSP is entirely responsible and accountable for the CCM control implementation. The CSC has no responsibility for implementing the control.
Control Ownership CSC-Owned	Control ownership and implementation responsibility is owned by the CSC. The CSC is entirely responsible and accountable for the CCM control implementation. The CSP has no responsibility for implementing the control.
Control Ownership Shared (Independent)	Control ownership and implementation responsibility is shared between the CSP and CSC (both parties should implement it) but there is no implementation dependency between the two. Both the CSP and CSC share CCM control implementation responsibility and accountability. Example: • An independent audit conducted by the CSC would not impact the CSP and vice versa • Both CSP and CSC must conduct training exercises but do so independently of one another
Control Ownership Shared (Dependent)	Control ownership and implementation responsibility is shared between CSP and CSC and there is an implementation dependency between the two (one party has to provide support to the other party for the control to be implemented). Both the CSP and CSC share CCM control implementation responsibility and accountability. Example: • The CSP should allow changes in its Geographic Location for at rest storage for a CSC to move its data to its required Geolocation. The CSC should also select its desired location in order for the CSP to facilitate the move • The CSP provides Identity and access management tools and capabilities to the CSC, however the CSC needs to properly configure access permissions

Table 1: SSRM Expressions

The above SSRM expression types are partially aligned with the Consensus Assessment Initiative Questionnaire (CAIQ) relevant column "SSRM Control Ownership". In addition to that, here, the new terms "Independent" and "Dependent" are introduced.

The implementation guidelines structure, as appears per each CCM control, is presented hereby: The first table introduces each CCM control specification, with a reference to its title, id and specification text, and sets the scope of SSRM expression and implementation guidelines determination.

Control Title	Control ID	Control Specification
Audit and Assurance Policy and Procedures	A&A-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.

Table 2: CCM control Title, ID and Specification

The second table introduces the SSRM expression and how it stands across the three cloud service models.

Control Ownership by Service Model		
IaaS	PaaS	SaaS
Shared (Independent)	Shared (Independent)	Shared (Independent)

Table 3: SSRM Control Ownership by Service Model

The third table, and in alignment to the SSRM, provides a justification rationale for the SSRM expression selection as well as the corresponding implementation guidelines that apply for each of the two cloud parties, CSP and CSC.

SSRM Guidelines	
CSP	CSC
Control Ownership Rationale. (text appears here) Implementation Guidelines. Applicable to all service models: (text appears here)	Control Ownership Rationale. (text appears here) Implementation Guidelines. Applicable to all service models: (text appears here)

Table 4: SSRM control ownership rationale and Implementation Guidelines

1.2.3 Target Audience

The intended audiences of this document include cloud consumers, cloud providers, cloud auditors, expert users willing to assist new CCM adopters, and neophytes willing to learn the best approaches to CCM control implementation.

The document assumes that readers have familiarity and knowledge of CCM v4, CAIQ, and CSA *Security Guidance for Critical Areas of Focus in Cloud Computing*.

Audience members are encouraged to follow industry-standard practices and innovate on their implementation journeys using this guidance.

1.3 Versioning

This is version 1.0 of the CCM introductory guidance document, published in February 2026.